

РО 1.4. Основные сервисы Linux для предприятия

Лекция 6. LDAP-каталог для предприятия

Цель лекции

Понять, зачем предприятию нужна централизованная служба каталогов

Объяснять LDAP-модель через DIT, DN, RDN, DC, OU, CN, UID, objectClass и атрибуты

Различать поиск записи, bind-аутентификацию и авторизацию пользователя

Читать базовые LDIF-записи пользователей и групп

Определять роль OpenLDAP, SSSD, NSS и PAM в Linux-инфраструктуре

Учебные вопросы

1. Проблема управления учетными записями на предприятии
2. Что такое LDAP? Базовые понятия и отличие от СУБД
3. Информационная модель LDAP: дерево каталога DIT
4. Процесс аутентификации в LDAP: LDAP Bind
5. Архитектура и установка OpenLDAP в Linux
6. Формат LDIF и управление данными
7. Интеграция Linux-клиентов с LDAP-каталогом
8. Диагностика, аудит и типовые ошибки

Учебный сценарий лекции

В организации используется учебный домен company.test и LDAP-база dc=company,dc=test
Сервер ldap01.company.test имеет адрес 192.168.10.60 и обслуживает каталог OpenLDAP
Клиент client01.company.test должен находить пользователей LDAP и выполнять вход через SSSD
В каталоге будут OU users и groups, пользователь uid=i.ivanov и группа cn=admins

1. Проблема управления учетными записями на предприятии

На одном Linux-сервере пользователей можно хранить локально в `/etc/passwd` и `/etc/shadow`

В сети из 100+ серверов ручное создание одинаковых учетных записей приводит к ошибкам и расхождениям

Увольнение сотрудника становится опасной процедурой, если его учетная запись остается на части серверов

Администратору нужен единый источник данных о пользователях, группах и служебных учетных записях

Локальная база пользователей и ее ограничения

`/etc/passwd` хранит основные сведения о локальных пользователях: логин, UID, GID, home и shell

`/etc/shadow` хранит хэши паролей локальных пользователей и параметры их срока действия

Эти файлы относятся к конкретному серверу и не синхронизируются автоматически с другими узлами

Копирование локальных файлов между серверами опасно: можно повредить UID, пароли и системные учетные записи

Служба каталогов и единый источник правды

Directory Service, служба каталогов, хранит структурированные записи об объектах инфраструктуры

Single Source of Truth, единый источник правды, означает, что учетные данные редактируются в одном месте

Authentication, аутентификация, проверяет личность пользователя по паролю, ключу или другому фактору

Authorization, авторизация, определяет, какие действия разрешены уже проверенному пользователю

ЦЕНТРАЛИЗОВАННОЕ УПРАВЛЕНИЕ УЧЕТНЫМИ ЗАПИСЯМИ

Единый источник правды для пользователей, групп и прав доступа



Единый источник данных для всей инфраструктуры



Безопасность единая политика и контроль доступа



Удобство управление в одном месте



Эффективность меньше ошибок, ниже затраты

ПОЧЕМУ ЛОКАЛЬНЫЕ УЧЕТНЫЕ ЗАПИСИ — ПРОБЛЕМА



Дублирование и ошибки

Учетные записи создаются вручную на каждом сервере. Легко допустить ошибку или забыть на каком-то узле.



Сложность управления

Изменение пароля или прав требует доступа к каждому серверу отдельно.



Риски безопасности

Увольнение сотрудника не приводит к блокировке доступа на всех серверах сразу.



Нет единой политики

Разные пароли, разные правила, разные настройки — нет контроля и дисциплины.



Нет единого аудита

Сложно отследить, кто и что делал в разных системах.



Чем больше серверов и сотрудников — тем выше риск и трудозатраты.

ЦЕНТРАЛИЗОВАННАЯ СЛУЖБА КАТАЛОГОВ (LDAP)



ПРЕИМУЩЕСТВА ЦЕНТРАЛИЗАЦИИ



Единое управление

Все учетные записи создаются и изменяются в одном месте.



Быстрая блокировка доступа

Уволили сотрудника — доступ блокируется на всех ресурсах мгновенно.



Единые политики безопасности

Пароли, сложность, срок действия, блокировки — одинаковые для всех.



Меньше ошибок и дублирования

Нет дублей учетных записей и конфликтов UID/GID.



Масштабируемость

Легко добавлять новые серверы и сервисы в инфраструктуру.



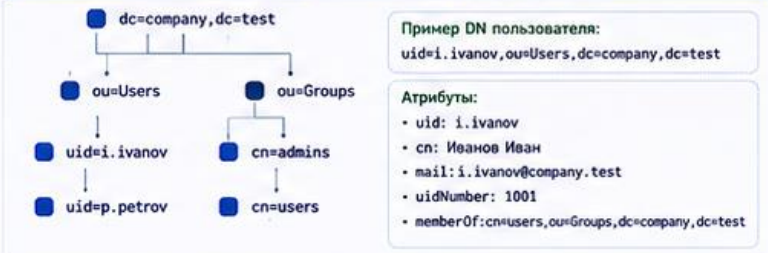
Централизованный аудит

Все действия пользователей и администраторов логируются в одном месте.



Централизованное управление экономит время, повышает безопасность и надежность ИТ-систем.

КАК РАБОТАЕТ АУТЕНТИФИКАЦИЯ



ЖИЗНЕННЫЙ ЦИКЛ УЧЕТНОЙ ЗАПИСИ



ПРОТОКОЛЫ И ИНТЕГРАЦИЯ



LDAP (TCP 389)
Стандартный порт LDAP



LDAPS (TCP 636)
LDAP поверх TLS



SSSD
Интеграция с Linux



PAM
Аутентификация пользователей



Samba / Kerberos
Доступ к файлам и сервисам



SSH / VPN / Wi-Fi
Используют LDAP для входа



ВАЖНО ПОМНИТЬ

- ✓ Один каталог — одна политика — единый контроль.
- ✓ Резервное копирование каталога обязательно!

2. Что такое LDAP? Базовые понятия и отличие от СУБД

LDAP (Lightweight Directory Access Protocol) — облегченный протокол доступа к службам каталогов. LDAP описывает операции поиска, чтения, добавления, изменения и удаления записей в каталоге. LDAP-каталог обычно оптимизирован под частое чтение и сравнительно редкое изменение записей. Для учетных записей это удобно: службы чаще проверяют пользователей, чем массово изменяют структуру каталога.

Почему LDAP не заменяют обычной СУБД

СУБД, система управления базами данных, например PostgreSQL или MySQL, хорошо подходит для сложных таблиц и транзакций

LDAP лучше подходит для иерархического справочника: пользователи, группы, подразделения и атрибуты

В LDAP запись имеет набор атрибутов, а не строку в связанной таблице с множеством JOIN-запросов

Каталог проектируют так, чтобы клиент быстро находил запись по DN, логину, группе или другому атрибуту

Порты и операции LDAP

Обычный LDAP использует TCP-порт 389; TCP обеспечивает надежную доставку запросов и ответов
LDAPS (LDAP over TLS) — LDAP поверх TLS-шифрования, обычно использует TCP-порт 636

Search ищет записи по базе и фильтру, например пользователя с uid=i.ivanov

Bind подключает клиента к каталогу от имени конкретной записи и проверяет учетные данные

Add, Modify и Delete изменяют данные каталога и требуют прав администратора или делегированных прав

3. Информационная модель LDAP: дерево каталога DIT

DIT (Directory Information Tree) — дерево информации каталога LDAP

DIT строится иерархически: сверху находится база каталога, ниже контейнеры и конкретные записи

Для учебной организации база каталога соответствует домену company.test: dc=company,dc=test

Иерархия помогает ограничивать поиск нужной веткой и логически разделять пользователей, группы и службы

DC, OU, CN и UID в дереве LDAP

DC (Domain Component) — компонент доменного имени: `company.test` записывается как `dc=company,dc=test`

OU (Organizational Unit) — организационная единица или контейнер, например `ou=users` и `ou=groups`

CN (Common Name) — общее имя объекта, часто применяется для групп, ролей и административных записей

UID (User ID) — идентификатор пользователя, который обычно соответствует логину Linux-пользователя

DN и RDN

DN (Distinguished Name) — уникальный полный путь к объекту в LDAP-дереве

RDN (Relative Distinguished Name) — относительное имя объекта на текущем уровне дерева

В DN `uid=i.ivanov,ou=users,dc=company,dc=test` часть `uid=i.ivanov` является RDN пользователя

Полный DN похож на абсолютный путь к файлу: он показывает не только имя, но и место объекта

Как читать DN пользователя

uid=i.ivanov указывает конкретную запись
пользователя

ou=users показывает, что пользователь расположен в
контейнере пользователей

dc=company,dc=test показывает базу каталога,
связанную с доменом company.test

Если в команде ошибиться хотя бы в одной части DN,
LDAP может вернуть No such object

Схемы данных, objectClass и атрибуты

Schema, схема данных, описывает допустимые классы объектов и атрибуты LDAP-записей

ObjectClass, класс объекта, определяет, какие атрибуты запись должна или может содержать

Attribute, атрибут, хранит конкретное свойство записи: uid, cn, sn, mail, uidNumber или loginShell

Одна запись может иметь несколько objectClass, если ей нужны разные наборы атрибутов

ObjectClass для пользователя Linux

inetOrgPerson описывает человека и добавляет атрибуты cn, sn, givenName и mail

posixAccount делает запись пригодной для Linux-входа через UID, GID, homeDirectory и loginShell

shadowAccount добавляет атрибуты, связанные со сроком действия пароля и учетной записи

Без posixAccount Linux-клиент может найти человека в каталоге, но не сможет использовать его как системного пользователя

DIT, DN, RDN И АТТРИБУТЫ ПОЛЬЗОВАТЕЛЯ

Как устроено дерево каталога LDAP и из чего состоит запись пользователя



DIT
Directory Information Tree –
дерево информации каталога.



DN
Distinguished Name –
уникальное имя записи
в дереве.



RDN
Relative Distinguished Name –
относительное имя узла
(один уровень).



Атрибуты
Пара «имя атрибута = значение»,
описывает объект каталога.

1. DIT – ДЕРЕВО КАТАЛОГА (ПРИМЕР company.test)



Дерево строится сверху вниз. Каждая запись (кроме корня) имеет ровно одного родителя. Это помогает логически группировать объекты и ограничивать область поиска.

2. DN – DISTINGUISHED NAME (ПОЛНОЕ ИМЯ ЗАПИСИ)

DN – это полный путь от записи до корня каталога. Он уникален в пределах всего каталога.

Пример DN пользователя Иванова Ивана:
`uid=i.ivanov,ou=users,dc=company,dc=test`

uid=i.ivanov → RDN (имя этой записи)
ou=users → Родитель (подразделение users)
dc=company → Родитель (домен company)
dc=test → Родитель (домен test, корень)

3. RDN – RELATIVE DN (ОТНОСИТЕЛЬНОЕ ИМЯ УЗЛА)

RDN – это имя записи на одном уровне дерева. Оно уникально среди «братьев» в том же контейнере.

Примеры RDN:
uid=i.ivanov – пользователь
cn=admins – группа
ou=users – подразделение
dc=company – компонент домена

RDN не содержит путь к предкам. Это только имя на текущем уровне.

4. АТТРИБУТЫ ПОЛЬЗОВАТЕЛЯ

Запись в LDAP – это набор атрибутов. Пример записи пользователя (Иванов Иван):

dn: uid=i.ivanov,ou=users,dc=company,dc=test
objectClass: inetOrgPerson
objectClass: posixAccount
objectClass: top
uid: i.ivanov
cn: Иванов Иван
sn: Иванов
givenName: Иван
mail: i.ivanov@company.test
uidNumber: 1001
gidNumber: 1001
homeDirectory: /home/i.ivanov
loginShell: /bin/bash
userPassword: {SSHA}x2s9dG1kJ9....

← DN записи
Классы объекта
Основные атрибуты
Системные атрибуты
← Атрибут пароля

Часто используемые атрибуты пользователя	
uid	Логин пользователя (уникален в пределах каталога)
cn	Common Name – отображаемое имя
mail	Адрес электронной почты
uidNumber	UID пользователя в Linux
gidNumber	Основная группа (GID)
homeDirectory	Домашний каталог
loginShell	Командная оболочка
userPassword	Хэш пароля (хранится в зашифрованном виде)

5. ПРИМЕРЫ DN В НАШЕМ КАТАЛОГЕ

Объект	RDN (имя узла)	DN (полное имя)
Корень каталога	dc=company,dc=test	dc=company,dc=test
Подразделение пользователей	ou=users	ou=users,dc=company,dc=test
Пользователь Иванов	uid=i.ivanov	uid=i.ivanov,ou=users,dc=company,dc=test
Группа администраторов	cn=admins	cn=admins,ou=groups,dc=company,dc=test

ВАЖНЫЕ ПРАВИЛА

- ✓ DN всегда записывается от имени записи к корню.
- ✓ Порядок RDN в DN важен.
- ✓ Параметры в DN разделяются запятой без пробелов.
- ✓ Атрибуты имеют виды: строковые, числовые, булевы, бинарные.
- ✓ Имена атрибутов чувствительны к регистру по стандарту, но обычно пишутся в нижнем регистре.

ПРИМЕРЫ ПОИСКА (LDAP-ФИЛЬТРЫ)

Найти пользователя по uid:
(uid=i.ivanov)
Найти всех пользователей в ou=users:
(&(objectClass=inetOrgPerson)(ou=users))
Найти пользователя по email:
(mail=i.ivanov@company.test)

ПОЛЕЗНЫЕ КОМАНДЫ

```
# Просмотр всей ветки  
ldapsearch -x -LLL -b dc=company,dc=test  
  
# Поиск пользователей по uid  
ldapsearch -x -LLL -b ou=users,dc=company,dc=test "(uid=i.ivanov)"  
  
# Просмотр конкретной записи по DN  
ldapsearch -x -LLL -b "uid=i.ivanov,ou=users,dc=company,dc=test"
```

ЗАПОМНИТЬ

DIT – структура дерева каталога.
DN – уникальный путь к записи.
RDN – имя записи на текущем уровне.
Атрибуты – описывают свойства объекта.

4. Процесс аутентификации в LDAP: LDAP Bind

LDAP Bind — операция подключения к каталогу от имени конкретной записи

Bind нужен, чтобы сервер понял, кто обращается к каталогу и какие права у этого клиента

Для проверки пароля пользователь или приложение выполняет bind с DN и паролем

Успешный bind подтверждает учетные данные, но не решает автоматически вопрос прав доступа к файлам или сервисам

Виды bind-аутентификации

Anonymous Bind — анонимное подключение без имени и пароля; в рабочих системах его часто ограничивают

Simple Bind — проверка по DN и паролю, безопасная только при использовании TLS-шифрования

SASL (Simple Authentication and Security Layer) — слой механизмов аутентификации, например через Kerberos

Kerberos — протокол сетевой аутентификации по билетам; его подробная настройка выходит за рамки этой лекции

Сценарий двойного запроса Search + Bind

Пользователь обычно вводит короткий логин i.ivanov, а LDAP bind требует полный DN

Приложение сначала выполняет Search и ищет запись с фильтром (uid=i.ivanov)

После нахождения DN приложение выполняет Bind от имени uid=i.ivanov,ou=users,dc=company,dc=test

Если пароль верен, приложение считает пользователя аутентифицированным и переходит к проверке прав

Проверка bind через ldapwhoami

ldapwhoami показывает, кем LDAP-сервер считает подключившегося клиента

Пример: ldapwhoami -x -H ldap://127.0.0.1 -D uid=i.ivanov,ou=users,dc=company,dc=test -W

Параметр -D задает DN пользователя, а -W запрашивает пароль интерактивно

Успешный результат выглядит как

dn:uid=i.ivanov,ou=users,dc=company,dc=test

Ошибка Invalid credentials (49) обычно означает неверный DN или пароль

ПОИСК DN И BIND-ПРОВЕРКА ПАРОЛЯ

Как клиент находит запись пользователя и проверяет пароль в LDAP-каталоге



Поиск DN

Находим нужную запись по фильтру в каталоге



Bind

Подключаемся от имени пользователя с паролем



Проверка

Сервер проверяет пароль и возвращает результат



Безопасность

Используйте LDAPS (TLS) для защиты паролей

1. ПОИСК DN ПОЛЬЗОВАТЕЛЯ

Сначала клиент должен найти полное DN (Distinguished Name) пользователя. Обычно выполняется LDAP-поиск (операция Search) по логину или email.



Пример поиска пользователя по uid:

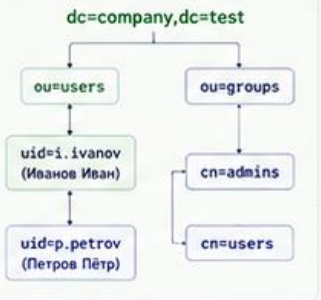
Base DN: dc=company,dc=test
Filter: (uid=i.ivanov)
Scope: subtree (вся поддерево)
Attributes: dn, uid, cn, mail

Пример результата поиска:

dn: uid=i.ivanov,ou=users,dc=company,dc=test
uid: i.ivanov
cn: Иванов Иван
mail: i.ivanov@company.test
...



Результат: клиент узнал полный DN пользователя и может использовать его для bind-проверки пароля.



2. BIND-ПРОВЕРКА ПАРОЛЯ

Клиент выполняет операцию Bind от имени найденного DN и передаёт пароль пользователя. Сервер проверяет пароль.



Что происходит на сервере:

- 1 Сервер ищет запись с указанным DN.
- 2 Если запись существует — сравнивает переданный пароль с сохранённым хэшем.
- 3 Возвращает результат bind-операции.
- 4 При неудаче — клиент получает ошибку и доступ не предоставляется.

Результаты bind-операции:



Успех (Bind OK)

Пароль верный. Сессия аутентифицирована. Клиент может выполнять другие операции (search, read и т.д.).



Ошибка (Invalid credentials)

Пароль неверный или запись не найдена. Доступ не предоставляется.



Bind-проверка не возвращает сам пароль. Сервер просто сообщает: «успех» или «ошибка».

3. ВСЁ ПРОЦЕСС: ПОИСК DN → BIND

Последовательность:



Пример диалога (упрощённо):

1. Поиск DN

Client → Server: search (uid=i.ivanov, base=dc=company,dc=test)
Server → Client: dn: uid=i.ivanov,ou=users,dc=company,dc=test

2. Bind с паролем

Client → Server: bind (dn=uid=i.ivanov,ou=users,dc=company,dc=test, password=*****)
Server → Client: bindResponse (resultCode=0) # ycnex

Неверный пароль

Client → Server: bind (dn=uid=i.ivanov,ou=users,dc=company,dc=test, password=*****)
Server → Client: bindResponse (resultCode=49, invalidCredentials) # ошибка



Важно помнить

- Пароль передаётся в открытом виде в обычном LDAP (порт 389).
- Используйте LDAPS (TCP 636) или StartTLS для шифрования.
- Не храните пароли в конфигурационных файлах приложений.
- Ограничивайте права учетных записей на bind и поиск.



ПОЛЕЗНЫЕ КОМАНДЫ (ldapsearch и ldapwhoami)

Поиск DN пользователя:

```
ldapsearch -x -H ldap://ldap01.company.test:389 \
-D "cn=admin,dc=company,dc=test" -W \
-b "dc=company,dc=test" -s sub \
"(uid=i.ivanov)" dn uid cn mail
```

Bind-проверка пароля (ldapwhoami):

```
ldapwhoami -x -H ldap://ldap01.company.test:389 \
-D "uid=i.ivanov,ou=users,dc=company,dc=test" -W

# Успех: dn:uid=i.ivanov,ou=users,dc=company,dc=test
# Ошибка: ldap_bind: Invalid credentials (49)
```

КЛЮЧЕВЫЕ ПОНЯТИЯ

- DN (Distinguished Name) — уникальный путь к записи в дереве каталога.
- Search — поиск записей по базе и фильтру.
- Bind — подключение от имени записи с проверкой учетных данных.
- Authentication — проверка личности (через password, key и др.).
- Authorization — определение прав после успешной аутентификации.

ДЛЯ ЧЕГО ЭТО НУЖНО



Единая входная точка для всех сервисов



Безопасный вход и контроль доступа



Простое управление учётными записями



Централизованный аудит и отчётность

5. Архитектура и установка OpenLDAP в Linux

OpenLDAP — открытая реализация LDAP-сервера и набора клиентских утилит

slapd (Standalone LDAP Daemon) — серверный демон

OpenLDAP, который обслуживает LDAP-запросы

В учебном стенде slapd работает на сервере

ldap01.company.test

Клиенты обращаются к серверу по адресу

ldap://192.168.10.60 или имени ldap01.company.test

Установка OpenLDAP и утилит

`sudo apt update` обновляет локальный список пакетов перед установкой

`sudo apt install slapd ldap-utils` -у устанавливает сервер OpenLDAP и консольные LDAP-утилиты

`ldap-utils` добавляет `ldapsearch`, `ldapadd`, `ldapmodify`, `ldapdelete` и `ldapwhoami`

После установки нужно проверить службу и выполнить первичную настройку базы каталога

RTC и cn=config

RTC (Real Time Configuration) — современная модель настройки OpenLDAP через дерево cn=config
cn=config хранит конфигурацию как LDAP-записи, а не как один старый плоский файл slapd.conf
Изменения в cn=config можно применять через LDAP-операции без полного перезапуска службы
Для начинающего администратора важно понимать: данные каталога и конфигурация slapd являются разными деревьями

Проверка службы slapd

`systemctl status slapd` показывает, запущена ли служба OpenLDAP

`sudo ss -tulpen | grep ':389'` проверяет, слушает ли сервер TCP-порт 389

`journalctl -u slapd -n 50 --no-pager` показывает последние сообщения службы

Если slapd не слушает порт 389, клиентские LDAP-запросы не смогут получить ответ

6. Формат LDIF и управление данными

LDIF (LDAP Data Interchange Format) — текстовый формат импорта, экспорта и изменения LDAP-записей. LDIF-файл описывает DN записи, классы objectClass и набор атрибутов.

Пустая строка отделяет одну запись от другой.

LDIF удобно хранить в репозитории учебного стенда и повторно применять на сервере.

Фрагмент LDIF пользователя

dn: uid=i.ivanov,ou=users,dc=company,dc=test задает
полный путь к пользователю

objectClass: inetOrgPerson добавляет атрибуты
человека: cn, sn, givenName и mail

objectClass: posixAccount добавляет Linux-атрибуты
uidNumber, gidNumber, homeDirectory и loginShell

userPassword: {SSHA}... хранит хэш пароля, а не
открытый текст пароля

Пароль пользователя и slapasswd

slapasswd создает хэш пароля, который можно вставить в атрибут userPassword

Пример: slapasswd запускает интерактивный ввод пароля и возвращает строку вида {SSHA}...

SSHA (Salted SHA) — хэш с солью, который не хранит исходный пароль в открытом виде

В учебных LDIF-файлах вместо реального хэша можно временно писать {SSHA}PASTE_HASH_HERE

Добавление и изменение записей

`ldapadd` добавляет новые записи из LDIF-файла в каталог

Пример: `ldapadd -x -D cn=admin,dc=company,dc=test -W -f users.ldif`

`ldapmodify` изменяет существующие записи через LDIF с операциями `add`, `replace` или `delete`

Пример: `ldapmodify -x -D cn=admin,dc=company,dc=test -W -f change-mail.ldif`

Если запись уже существует, `ldapadd` вернет ошибку `Already exists`

Поиск данных через ldapsearch

ldapsearch извлекает записи из каталога и помогает проверить, видит ли сервер нужные данные

Пример: ldapsearch -x -LLL -b dc=company,dc=test
'(uid=i.ivanov)' dn cn mail

Параметр -b задает base DN, фильтр (uid=i.ivanov) ограничивает результат одной учетной записью

Атрибуты dn cn mail в конце команды уменьшают вывод и оставляют только нужные поля

Если вывод пустой, сначала проверяют base DN, фильтр и наличие записи



Пример записи пользователя

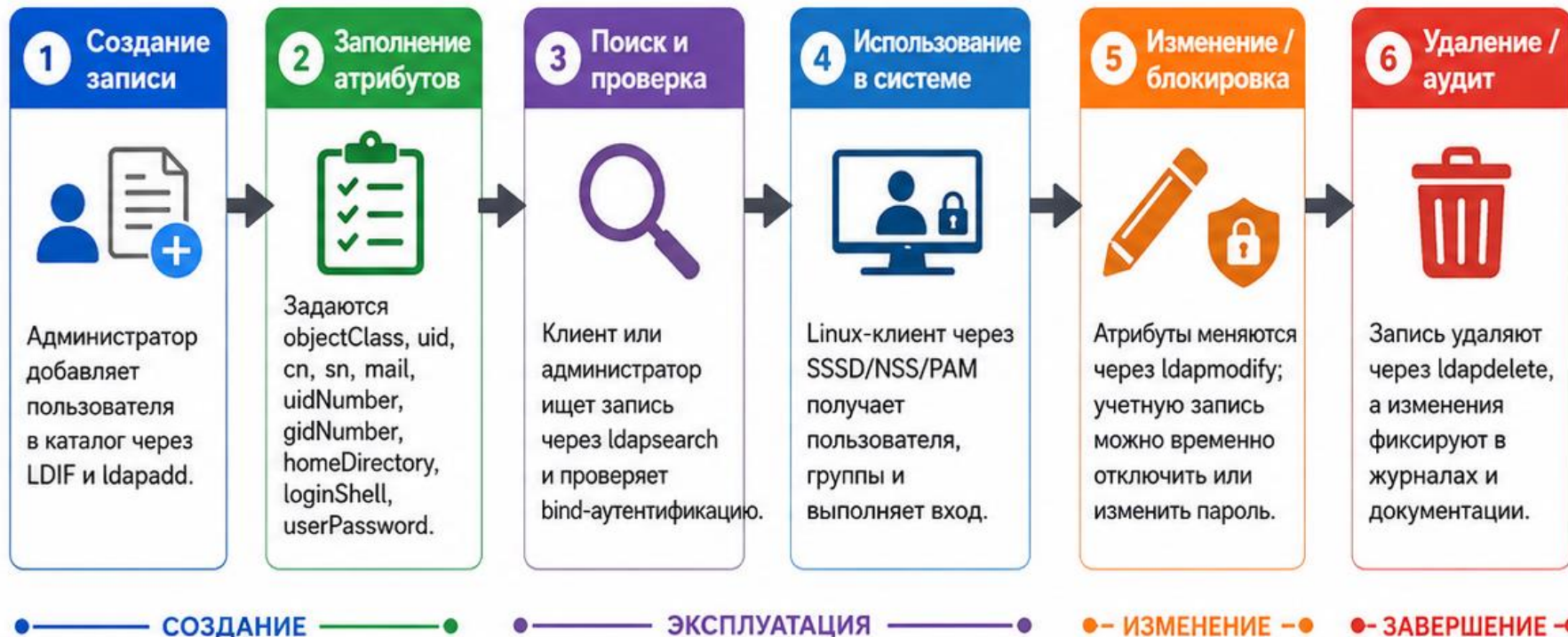
```
dn: uid=i.ivanov,
ou=users,
dc=company,
dc=test
```

```
objectClass:
inetOrgPerson
objectClass:
posixAccount
```

```
uid: i.ivanov
cn: Иванов Иван
mail: i.ivanov@
company.test
uidNumber: 1001
gidNumber: 1001
homeDirectory:
/home/i.ivanov
loginShell:
/bin/bash
```

Жизненный цикл записи в LDAP

От создания пользователя до изменения, использования, блокировки и удаления



Что важно помнить

1

Каталог — единый источник данных о пользователях.

2

DN должен быть точным, иначе поиск и bind не сработают.

3

Для Linux-входа важен objectClass posixAccount.

4

Пароли должны передаваться по защищенному каналу: LDAPS или StartTLS.

5

Удаление записи должно сопровождаться аудитом и проверкой зависимостей.



LDIF



OpenLDAP



SSSD/NSS/PAM



Linux-вход пользователя



Основные команды



ldapadd — добавить запись



ldapsearch — найти запись



ldapwhoami — проверить bind



ldapmodify — изменить атрибуты



ldapdelete — удалить запись

7. Интеграция Linux-клиентов с LDAP-каталогом

Linux-клиент должен не только проверить пароль, но и понять, кто такой пользователь для системы

Для входа нужны UID, GID, домашний каталог, shell и группы пользователя

LDAP хранит эти данные, а Linux должен научиться получать их из каталога

Современный стек интеграции обычно строится на SSSD, NSS и PAM

NSS: где Linux ищет пользователей

NSS (Name Service Switch) — механизм выбора источников системной информации в Linux
/etc/nsswitch.conf определяет, где искать passwd, group, hosts и другие базы

Для LDAP-входа строка passwd может использовать источники files и sss

Источник files означает локальные файлы, а sss означает обращение к SSSD

PAM: как Linux проверяет пароль

PAM (Pluggable Authentication Modules) — модульная система аутентификации Linux

PAM подключается к login, sshd, sudo и другим программам входа

Через PAM система проверяет пароль, применяет ограничения и открывает пользовательскую сессию

При интеграции с LDAP PAM обычно обращается не напрямую к LDAP, а к SSSD

SSSD как посредник между Linux и LDAP

SSSD (System Security Services Daemon) — служба, которая подключает Linux-клиента к внешним каталогам

SSSD общается с LDAP, кэширует пользователей и группы, а также передает данные NSS и PAM

Кэш SSSD помогает входить пользователю, если каталог временно недоступен и политика это разрешает

/etc/sss/sss.conf хранит адрес LDAP-сервера, search base и параметры безопасности клиента

ВХОД LINUX-ПОЛЬЗОВАТЕЛЯ ЧЕРЕЗ SSSD, NSS И PAM

Как происходит аутентификация и получение данных пользователя из LDAP-каталога



PAM
Pluggable Authentication
Modules – оценивает
политику входа и запускает
модули аутентификации



NSS
Name Service Switch –
получает сведения о
пользователях и группах
через источники



SSSD
System Security Services Daemon –
клиент, который общается с LDAP,
учищает данные и отвечает
NSS и PAM



LDAP
Каталог (OpenLDAP) –
централизованное хранилище
учетных записей, групп
и атрибутов

АРХИТЕКТУРА



РОЛИ КОМПОНЕНТОВ

- PAM** – проверяет пароли/учетные данные, политику доступа, запускает сессии (login, sshd, sudo и др.).
- NSS** – по имени пользователя находит UID, GID, домашнюю директорию, оболочку и группы. Источник данных: SSSD.
- SSSD** – получает данные из LDAP, кэширует их локально и предоставляет ответы NSS и PAM. Поддерживает bind и обновление кэша.
- LDAP** – хранит записи пользователей и групп в DIT.

НЕОБХОДИМЫЕ ПАКЕТЫ (на клиенте)

- Ubuntu/Debian: `sudo apt install sssd sssd-tools libnss-sss libpam-sss`
- Red Hat/CentOS: `sudo dnf install sssd sssd-client sssd-tools`
- OpenSUSE: `sudo zypper install sssd sssd-tools`

КЛЮЧЕВЫЕ ФАЙЛЫ

- `/etc/sss/sss.conf` – конфигурация SSSD (домен, LDAP, кэш)
- `/etc/nsswitch.conf` – порядок источников пользователей и групп
- `/etc/pam.d/common-auth` – PAM: правила аутентификации
- `/etc/pam.d/common-session` – PAM: правила сессии
- `/var/lib/sss/db/` – локальная база (кэш) SSSD
- `/var/log/sss/` – `journalctl -u sssd` – логи SSSD

ДИАГНОСТИКА И ПРОВЕРКА

- Проверка статуса SSSD: `systemctl status sssd`
- Проверка домена: `sssctl domain-status`
- Список пользователей: `getent passwd i.ivanov`
- Список групп: `getent group users`
- Тест аутентификации: `ssh i.ivanov@localhost`
- Логи SSSD: `journalctl -u sssd -f`

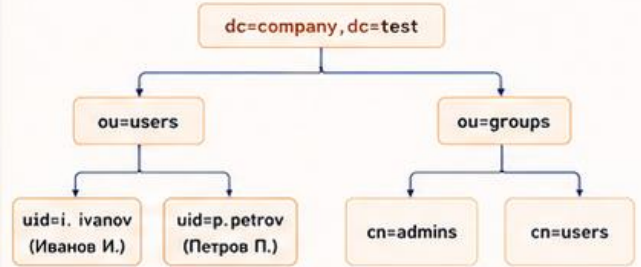
ЖИЗНЕННЫЙ ЦИКЛ ВХОДА ПОЛЬЗОВАТЕЛЯ

- Пользователь вводит логин и пароль (например, через SSH или на консоли). **PAM** PAM получает запрос на аутентификацию.
- PAM обращается к модулю аутентификации SSSD. **PAM** Управление передается `pam_sss.so`.
- SSSD проверяет кэш: есть ли пользователь и данные о нем. **SSSD** Если есть и кэш не устарел – переходим к шагу 6. Если нет или кэш устарел – обращаемся к LDAP.
- SSSD выполняет bind в LDAP от имени пользователя (или service bind) и проверяет пароль. **SSSD → LDAP** LDAP проверяет пароль и возвращает результат.
- SSSD сохраняет данные пользователя и групп в локальный кэш. **SSSD** Данные будут использоваться повторно без обращения к LDAP.
- NSS запрашивает сведения о пользователе (UID, GID, home, shell, группы и т.д.). **NSS** NSS обращается к SSSD через `nss_sss`.
- SSSD отдает данные из кэша (или, при необходимости, запрашивает в LDAP) и возвращает их NSS. **SSSD** Пользователь и его группы успешно найдены.
- PAM применяет политики (expiry, блокировка, время входа, MFA и др.) и создает сессию. **PAM** Если все проверки пройдены – вход разрешен.
- Создается пользовательская сессия (оболочка, окружение, home). **PAM / systemd** Сессия активна. Логи записаны в журналы.



В следующий раз вход будет быстрее: данные возьмутся из кэша SSSD.

ПРИМЕР ИЕРАРХИИ В LDAP (DIT)



ПРИМЕР sssd.conf (фрагмент)

```
[sss]  
config_file_version = 2  
services = nss, pam  
[domain/company.test]  
id_provider = ldap  
auth_provider = ldap  
ldap_uri = ldap://ldap01.company.test  
ldap_search_base = dc=company,dc=test  
ldap_tls_reqcert = demand_cache  
cache_credentials = True  
enumerate = False
```



ПРИМЕР nsswitch.conf (фрагмент)

```
passwd: files sss  
shadow: files sss  
group: files sss  
hosts: files dns  
netgroup: nis
```



КЭШИРОВАНИЕ (SSSD)

- ✓ Данные пользователей и групп сохраняются локально в SQLite-базе.
- ✓ Повторные входы работают даже при недоступности LDAP (в пределах TTL).
- ✓ Параметры кэша: `entry_cache_timeout`, `negative_timeout`, `refresh_expired_interval`.
- ✓ При необходимости: `sss_cache -E` (очистить кэш)



ПРЕИМУЩЕСТВА ТАКОГО ПОДХОДА

- ✓ Единая учетная запись для всех серверов.
- ✓ Централизованная политика и управление доступом.
- ✓ Быстрый вход за счет кэширования.
- ✓ Работает по защищенному каналу (LDAPS/TLS).



БЕЗОПАСНОСТЬ

- ✓ Используйте LDAPS (порт 636) и проверку сертификатов.
- ✓ Ограничивайте права bind-пользователей в LDAP.
- ✓ Контролируйте доступ к серверам и журналам.
- ✓ Настраивайте сложные пароли и политику PAM.



8. Диагностика, аудит и типовые ошибки

Диагностика LDAP начинается с разделения проблем сервера, сети, поиска записи и проверки пароля
slapcat выводит содержимое базы OpenLDAP
напрямую на сервере и помогает проверить, есть ли запись в базе

Пример: `slapcat | grep 'uid: i.ivanov'` быстро показывает, присутствует ли пользователь в дампе базы

ldapsearch проверяет запрос так, как его видит LDAP-клиент через сетевой интерфейс службы

Типовые ошибки LDAP

Invalid credentials (49) обычно означает неверный пароль или неверный Bind DN

No such object чаще всего связан с неправильным base DN или отсутствующей OU

Size limit exceeded означает, что запрос вернул больше записей, чем разрешает лимит сервера

Конфликт UID/GID приводит к неправильным владельцам файлов или проблемам доступа на Linux-клиенте

Ошибки LDAPS часто связаны с тем, что клиент не доверяет корневому CA сервера

Итоги лекции

LDAP-каталог централизует учетные записи, группы и атрибуты пользователей предприятия

DIT, DN и RDN позволяют однозначно расположить запись внутри дерева каталога

ObjectClass и атрибуты определяют, какие данные может хранить пользователь или группа

Bind проверяет учетные данные, а Search помогает найти DN и нужные атрибуты

Интеграция Linux-клиентов с LDAP строится через SSSD, NSS и PAM

Контрольные вопросы

Почему локальные учетные записи плохо подходят для сети из большого числа серверов?

Чем служба каталогов LDAP отличается от реляционной СУБД?

Расшифруйте DN, RDN, OU, CN, DC и приведите пример DN пользователя

Зачем пользователю Linux в LDAP нужен objectClass posixAccount?

Как работает сценарий Search + Bind при входе пользователя?

Для чего используется LDIF и какие команды